

Threat Hunting Fundamentals Summary

Threat hunting is an active, human-led, and hypothesis-driven practice that systematically combs through network data to identify stealthy, advanced threats that evade existing security solutions.

Core Objectives & Strategy

- **Reducing Dwell Time:** The principal objective is to substantially reduce "dwell time"—the duration between a security breach and its detection—by recognizing malicious entities at the earliest stage of the cyber kill chain.
- **Proactive Approach:** It represents a paradigm shift from reactive defense-oriented tactics to a proactive, offensive strategy.
- **Key Facets:** Successful hunting requires a practical comprehension of the threat landscape, adversarial Tactics, Techniques, and Procedures (TTPs), and cognitive empathy with the attacker's mindset.

Relationship with Incident Handling

Threat hunting and incident handling have a symbiotic relationship:

- **Preparation:** Teams establish clear rules of engagement and operational protocols.
- **Detection & Analysis:** Hunters use their acumen to augment investigations and uncover additional Indicators of Compromise (IoCs).
- **Post-Incident Activity:** Hunters contribute recommendations to fortify the organization's overall security posture based on their extensive expertise.

When to Hunt

Threat hunting should be a sustained, forward-thinking activity, with immediate operations called for in specific instances:

- **New Intel:** When new information on an adversary or vulnerability comes to light.
- **New Indicators:** When new IoCs are associated with a known adversary.
- **Anomalies:** When multiple network anomalies are detected within a short period.
- **During Incident Response:** Conducting hunting simultaneously with IR helps expose connected threats and understand the full extent of a compromise.
- **Periodic Actions:** Regular, proactive hunting is essential to discover latent threats that have slipped past security defenses.

Role of Risk Assessment

Risk assessment acts as a key enabler for threat hunting:

- **Prioritizing Efforts:** By identifying "crown jewels" and critical assets, teams can focus their efforts on areas of greatest potential impact.
- **Hypothesis Development:** Understanding the threat landscape assists in developing effective hunting hypotheses.
- **Vulnerability Insight:** Knowing specific weaknesses allows hunters to look for exploitation indicators, such as anomalies in user privilege levels.

The Threat Hunting Process

Threat hunting is a structured cycle used to proactively find hidden threats.

Steps in the Threat Hunting Process

- **Setting the Stage:** Prepare by understanding the threat landscape, identifying critical assets, and ensuring logging tools (like SIEM, EDR, and IDS) are correctly configured.
- **Formulating Hypotheses:** Create educated, **testable** predictions based on threat intelligence or suspicious alerts.
- **Designing the Hunt:** Choose the data sources, tools, and specific patterns or Indicators of Compromise (IoCs) to search for.
- **Data Gathering and Examination:** Actively collect logs and network data to find evidence that supports or refutes your hypothesis.
- **Evaluating Findings and Testing Hypotheses:** Interpret the results to confirm if a threat exists and determine its impact.
- **Mitigating Threats:** If a threat is confirmed, take action (e.g., isolate systems, patch vulnerabilities) to stop the damage.
- **After the Hunt:** Document findings, update detection rules, and share lessons learned to improve future security.
- **Continuous Learning and Enhancement:** Constantly refine tools and methods based on new intelligence and previous hunt experiences.

Key Rules

- **Hypotheses must be testable:** It is **False** that you can formulate hypotheses that are not testable; a hypothesis must be specific and testable to guide the search.

Threat Hunting Glossary & Frameworks

This guide covers essential terms and models used in cybersecurity and threat hunting.

Core Concepts

- **Adversary:** An unauthorized entity (such as a cybercriminal, insider threat, or state-sponsored operator) seeking to infiltrate an organization for financial gain, intellectual property, or sensitive data.
- **Advanced Persistent Threat (APT):** A highly organized group or nation-state entity that uses sophisticated strategic planning and extensive resources to maintain persistence against high-value targets over a long period.
- **Threat:** A concept composed of three fundamental factors: **Intent** (the motivation), **Capability** (tools and financial backing), and **Opportunity** (vulnerabilities or events that allow for an attack).
- **Indicators of Compromise (IOCs):** Digital artifacts, such as file hashes, suspicious IP addresses, or domain names, that serve as signposts of active or past malicious activity.
- **TTPs (Tactics, Techniques, and Procedures):**
 - **Tactics:** The 'why'—the strategic objectives of an adversary.
 - **Techniques:** The 'how'—the general methods used to achieve tactical goals.
 - **Procedures:** The 'recipe'—the granular, step-by-step instructions for executing a technique.

Analytical Models

- **Pyramid of Pain:** A visualization hierarchy that shows how difficult it is for an adversary to change specific indicators.
 - As you move up the pyramid, detection becomes more challenging, but it forces the adversary to spend more effort and cost to change their methods.
 - **Bottom (Easier):** Hash values, IP addresses, Domain names.
 - **Middle:** Network/Host Artifacts, Tools.
 - **Top (Hardest):** TTPs.
- **Diamond Model of Intrusion Analysis:** A framework used to understand the fundamental aspects of a cyber intrusion through four interconnected components:
 - **Adversary:** The actor responsible for the attack.
 - **Capability:** The tools and TTPs used.
 - **Infrastructure:** The physical or virtual resources (servers, IPs) used to facilitate the attack.
 - **Victim:** The target of the intrusion.

Cyber Threat Intelligence (CTI) Fundamentals

Cyber Threat Intelligence (CTI) is the collection and analysis of information to help organizations transition from reactive defense to a proactive, anticipatory posture.

Four Principles of Effective CTI

- **Relevance:** Information must be pertinent to the organization's specific environment, software, and industry to be valuable.
- **Timeliness:** Intelligence must be communicated quickly; the value of data depreciates as it ages and becomes obsolete.
- **Actionability:** Intelligence must provide clear directives for defense teams to take action.
- **Accuracy:** Information must be verified to prevent wasted resources; uncertain data should be labeled with a confidence indicator.

CTI vs. Threat Hunting

- **Threat Intelligence (Predictive):** Focuses on anticipating an adversary's moves, targets, and methods.
- **Threat Hunting (Reactive & Proactive):** An active operation to determine if an adversary is—or was—present in the network, often triggered by an event or incident.

Categories of Intelligence

1. **Strategic Intelligence:** Consumed by C-suite executives; focuses on the "Who?" and "Why?" regarding adversary campaigns and long-term risks.
2. **Operational Intelligence:** Produced for mid-level management; focuses on the "How?" and "Where?" by analyzing adversary TTPs and campaigns in detail.
3. **Tactical Intelligence:** Delivered to network defenders; contains immediate, actionable technical details like IP addresses, hashes, and domains.

Processing a Tactical Intelligence Report

To maximize the value of tactical reports (such as an Emotet campaign analysis), follow this methodology:

1. **Comprehend Scope:** Understand the narrative and business pertinence.
2. **Classify IOCs:** Group Indicators of Compromise (IOCs) into Network-based, Host-based, and Email-based categories.
3. **Understand Lifecycle:** Map TTPs to the MITRE ATT&CK framework to forecast attacker behavior.
4. **Analyze & Validate:** Authenticate IOCs using sources like VirusTotal and consider the age/context of the data to avoid false positives.
5. **Integrate:** Add authenticated IOCs to security infrastructure (firewalls, EDR, email gateways) while documenting changes.

6. **Proactive Hunting:** Search for broader TTPs beyond simple IOC matching (e.g., hunting for suspicious PowerShell usage).
7. **Continuous Learning:** Monitor for hits, trigger incident response when necessary, and contribute new findings back to the security community.

Threat Hunt Summary: Stuxbot Campaign Investigation

This report summarizes the threat hunting investigation into the "Stuxbot" malware collective using the Elastic SIEM stack.

Initial Breach & Delivery

- **Infection Vector:** The attack utilized phishing emails containing links to malicious OneNote files (`invoice.one`).
- **Delivery:** User "Bob" on machine `WS001` (IP `192.168.28.130`) downloaded the file via Microsoft Edge from a hosting provider (`file.io`).
- **Execution:** Opening the file triggered `invoice.bat` , which launched a PowerShell script to download a malicious payload from Pastebin.

Malicious Activity & Persistence

- **RAT Characteristics:** The malware is a modular Remote Access Trojan (RAT) capable of screen dumping, executing Mimikatz, and providing an interactive CMD shell.
- **Persistence:** The attacker deployed an executable named `default.exe` . The SHA256 hash of this file matched intelligence provided in the threat report.
- **C2 Communication:** The malware leveraged **Ngrok** to obfuscate command-and-control (C2) traffic, communicating over port 443.

Lateral Movement & Escalation

- **Active Directory Discovery:** The attacker executed **SharpHound** to map the Active Directory and identify escalation paths.
- **Lateral Movement:** Evidence of `PSEXESVC` (a component of Microsoft-signed PsExec) confirmed that the attacker moved laterally to the `PKI` server.
- **Account Compromise:** The user account `svc-sql1` was identified as compromised following successful password brute-force attempts originating from `WS001` .

Investigative Methodology

- **Tooling:** The investigation relied on Windows audit logs, Sysmon (Events 1, 3, 11, 15, and 22), PowerShell logs, and Zeek network data.

- **DNS Analysis:** Zeek logs provided critical visibility into DNS queries, enabling the detection of communication with `file.io` and the dynamic C2 infrastructure hosted on `ngrok.io`.
- **Correlation:** By correlating process creation events (e.g., `ONENOTE.EXE` spawning `cmd.exe`) with network logs, the team successfully reconstructed the entire attack chain from the initial phishing email to domain-wide compromise.